

Identification Protocol Exercises

December 23, 2025

Why is a challenge-response protocol vulnerable to an *offline* dictionary attack if the attacker eavesdrops on the traffic?

- ① Because the server sends the password in plain text.
- ② Because the attacker can use the intercepted challenge and response to verify password guesses without interacting with the server.
- ③ Because MAC algorithms are inherently weak and can be reversed easily.
- ④ Because the challenge R is always the same for every login attempt.

Question 2: Password attacks

- 1 Hash h of 8-char password (100 symbols each), SHA256, no salt. One machine does 10,000,000 SHA256/s; attacker rents 1000 machines. Worst-case seconds to exhaustively find the password?
- 2 Do public salts help (attacker also knows the salt)?
- 3 Do slow hashes like PBKDF2 help?
- 4 With 10,000 user hashes under same assumptions and resources, worst-case time to recover all? Explain (dominated by SHA256 work).
- 5 Do public salts slow down the attack in 4?

A classic identification protocol works as follows. Fix a cyclic group G of prime order q and generator g . Choose random $x \in \mathbb{Z}_q$ and set $\text{sk} := x$ and $\text{vk} := g^x$. Then:

- 1 Prover picks random $r \in \mathbb{Z}_q$ and sends $R := g^r$.
- 2 Verifier picks random challenge $c \in \{1, \dots, B\}$ and sends c .
- 3 Prover sends $z := x \cdot c + r \in \mathbb{Z}_q$.
- 4 Verifier accepts if $g^z = (\text{vk})^c \cdot R$.

Answer the following questions:

- 1 Show an honest prover is always accepted.
- 2 If steps (1) and (2) are swapped (challenge first), show the protocol is insecure: an attacker knowing vk but not x can cause acceptance.
- 3 If the prover reuses R for challenges c, c' with responses z, z' , show how the verifier recovers x from $(\text{vk}, R, c, c', z, z')$.

Question 4: Encryption-based challenge-response ID

Identification via symmetric encryption (E, D) over (K, M, C) :

- setup $sk = vk = k \leftarrow_R K$;
- verifier sends $c := E(k, m)$ for random $m \in M$;
- prover returns $m' := D(k, c)$; accept if $m = m'$.

Answer the following questions:

- 1 Determine security / give attacks for:
 - One-time pad with $K = M = C = \{0, 1\}^{128}$.
 - AES-CBC with random IV, $M = \{0, 1\}^{128}$.
 - AES-GCM, $M = \{0, 1\}^{128}$.
- 2 If k is derived from a user password, can an eavesdropper on one successful transcript mount a dictionary attack to expose k ? Explain.
- 3 Modify the protocol so vk can be public without affecting security.